Apuntes de Ciberseguridad

Herramientas · OSINT · Normativas · Conceptos base

Comandos Linux · TheHarvester · Shodan · Wireshark · Rootkits · ISO 27001 · NIST

Recopilación personal de herramientas, conceptos y normativas de ciberseguridad. Organizado como referencia de estudio y base para profundización posterior.

1. Comandos Básicos en Kali Linux

La terminal es la herramienta principal en ciberseguridad. Dominar estos comandos es el punto de partida para cualquier actividad técnica en Kali Linux o cualquier distribución basada en Debian/Ubuntu.

Comando	Función	Ejemplo
ls	Listar archivos y carpetas del directorio actual	ls -la
cd [carpeta]	Entrar a una carpeta. cd .. retrocede un nivel	cd /home/usuario
pwd	Mostrar la ruta completa del directorio actual	pwd
cat [archivo]	Mostrar el contenido de un archivo en pantalla	cat /etc/passwd
mkdir [nombre]	Crear un nuevo directorio	mkdir resultados
rmdir [nombre]	Eliminar un directorio vacío	rmdir tmp
touch [archivo]	Crear un archivo vacío	touch notas.txt
rm [archivo]	Eliminar un archivo (rm -rf para directorios con contenido)	rm archivo.txt
cp [origen] [dest]	Copiar archivos o directorios	cp file.txt backup/
mv [origen] [dest]	Mover o renombrar archivos	mv viejo.txt nuevo.txt
clear	Limpiar la pantalla de la terminal	clear
whoami	Mostrar el usuario actual	whoami
sudo	Ejecutar comando con privilegios de administrador	sudo apt update
grep	Buscar texto dentro de archivos o salidas	grep 'error' log.txt
| (pipe)	Encadenar la salida de un comando como entrada del siguiente	cat log.txt | grep error
chmod	Cambiar permisos de archivos	chmod +x script.sh
man [cmd]	Ver el manual completo de cualquier comando	man nmap

1.1 Comandos de red más usados

Comando	Función
ifconfig / ip a	Ver interfaces de red e IPs asignadas
netstat -tulpn	Ver puertos en escucha y conexiones activas
ping [IP/host]	Verificar conectividad básica con un host
nslookup / dig	Consultar registros DNS de un dominio
curl [URL]	Hacer peticiones HTTP desde la terminal
wget [URL]	Descargar archivos desde una URL
ssh usuario@IP	Conectarse a un servidor remoto por SSH

scp origen dest	Copiar archivos de forma segura entre hosts vía SSH

✔ El comando man es tu mejor amigo: man nmap, man grep, man iptables te dan la documentación completa de cualquier herramienta. También puedes usar herramienta --help para un resumen rápido.

2. OSINT — TheHarvester

OSINT (Open Source Intelligence) es la recolección de información a partir de fuentes públicas y accesibles. Es siempre el primer paso en una evaluación de seguridad — conocer la superficie de ataque antes de interactuar con los sistemas.

2.1 ¿Qué es TheHarvester?

TheHarvester es una herramienta de OSINT incluida en Kali Linux que recopila información sobre un dominio o persona desde múltiples fuentes públicas: motores de búsqueda, redes sociales, registros DNS, certificados TLS y más.

Información que puede recopilar:

- Direcciones de correo electrónico asociadas a un dominio
- Subdominios y nombres de host
- Direcciones IP y rangos de red
- URLs y endpoints expuestos
- Nombres de empleados en redes sociales

2.2 Instalación

```
sudo apt update && sudo apt install theharvester -y
```

2.3 Uso y parámetros

Parámetro	Función	Ejemplo
-d	Dominio o usuario a investigar	-d empresa.com
-b	Fuente de datos (motor de búsqueda o red social)	-b google
-l	Límite de resultados a obtener	-l 500
-f	Guardar resultados en archivo HTML/XML	-f resultados
-v	Modo verbose — más detalle en la salida	-v

2.4 Ejemplos de uso

```
# Búsqueda básica en Google
theharvester -d empresa.com -b google -l 200

# Buscar en todas las fuentes disponibles
theharvester -d empresa.com -b all -l 500

# Guardar resultados en archivo
theharvester -d empresa.com -b all -l 500 -f empresa_recon

# Extraer solo correos del archivo de resultados
```

```
cat empresa_recon.html | grep -i '@empresa.com'
```

2.5 Fuentes de datos disponibles

Fuente	Tipo de información	Notas
google	Emails, URLs, subdominios	Límites de rate — puede requerir API key
bing	Emails, URLs, subdominios	Alternativa útil a Google
linkedin	Nombres de empleados, cargos	Requiere cuenta
twitter/x	Usuarios, menciones	Limitado por la API actual
shodan	IPs, puertos, banners	Requiere API key de Shodan
certspotter	Subdominios via cert transparency	Muy efectivo para subdominios
dnsdumpster	Subdominios, registros DNS	Gratuito y rápido
all	Todas las fuentes	Más lento pero más completo

■ TheHarvester solo consulta información públicamente disponible. No interactúa directamente con los sistemas del objetivo — es reconocimiento completamente pasivo.

3. Shodan — Motor de Búsqueda de Dispositivos

Shodan es un motor de búsqueda especializado que indexa dispositivos conectados a Internet: servidores, routers, cámaras IP, sistemas industriales SCADA, impresoras, bases de datos expuestas, y cualquier dispositivo con IP pública. A diferencia de Google (que indexa páginas web), Shodan indexa banners de servicios.

3.1 ¿Cómo funciona Shodan?

Shodan tiene escáneres propios que recorren continuamente el espacio de IPs públicas y se conectan a puertos comunes (80, 443, 22, 21, 23, 3306, etc.). Captura los banners que responden — los primeros bytes de respuesta que revelan versión, configuración y características del servicio.

- Un banner de Apache puede revelar: versión, módulos instalados, sistema operativo
- Un banner de SSH revela: versión del servidor, algoritmos soportados
- Una cámara IP expuesta puede responder directamente con el stream de video

3.2 Instalación del cliente CLI

```
sudo apt update && sudo apt install python3-pip -y
pip install shodan
shodan init TU_API_KEY
```

La API key gratuita permite búsquedas básicas. Las cuentas de pago dan acceso a más filtros, historial y mayor volumen de resultados.

3.3 Búsquedas desde la terminal

```
# Búsqueda básica
shodan search webcam

# Filtrar por país y puerto
shodan search 'port:80 country:ES'

# Dispositivos con captura de pantalla (paneles de admin, cámaras)
shodan search 'has_screenshot:true title:"Live View"'

# Información de un host específico
shodan host 8.8.8.8

# Ver tu propia IP pública y qué expone
shodan myip
shodan host $(shodan myip)

# Buscar paneles de administración expuestos
shodan search 'title:"admin" port:8080'

# Bases de datos MongoDB sin autenticación
shodan search 'product:MongoDB -authentication'
```

3.4 Filtros útiles de Shodan

Filtro	Función	Ejemplo
country:XX	Filtrar por código de país ISO	country:MX country:AR
port:N	Filtrar por puerto específico	port:22 port:3389
product:	Filtrar por software/producto	product:Apache product:nginx
version:	Filtrar por versión específica	version:2.4.49
hostname:	Buscar por nombre de host	hostname:.empresa.com
org:	Filtrar por organización/ASN	org:"Amazon"
os:	Filtrar por sistema operativo	os:"Windows 2003"
title:	Buscar en títulos de páginas web	title:"login"
has_screenshot:true	Solo dispositivos con captura visual	has_screenshot:true
vuln:CVE-XXXX	Buscar dispositivos con vulnerabilidad específica	vuln:CVE-2021-44228

3.5 Uso defensivo — proteger tu exposición

Shodan es tan útil para el atacante como para el defensor. Cualquier organización debería usar Shodan para auditar su propia exposición antes de que lo haga un atacante.

- **Cambiar credenciales por defecto** en todos los dispositivos al ponerlos en producción
- **Deshabilitar servicios innecesarios** — si no necesitas acceso remoto, apágalo
- **Mantener firmware actualizado** — versiones antiguas aparecen en búsquedas de vulnerabilidades
- **Firewall perimetral** — bloquear puertos que no deben ser accesibles desde Internet
- **VPN para acceso remoto** — no exponer paneles de administración directamente
- **Monitorear con Shodan Alerts** — notificaciones cuando tu IP/dominio aparece indexado

✔ Comando para ver qué expone tu propia infraestructura: shodan host $(shodan myip). Si ves servicios inesperados, hay trabajo que hacer.

4. Wireshark — Análisis de Tráfico de Red

Wireshark es el analizador de protocolos de red más usado del mundo. Permite capturar y analizar en tiempo real todos los paquetes que pasan por una interfaz de red. Es esencial para diagnóstico de red, análisis forense y detección de amenazas.

4.1 ¿Qué puede ver Wireshark?

- Todos los paquetes que pasan por la interfaz de red (en modo promiscuo)
- Contenido completo de tráfico no cifrado: HTTP, FTP, Telnet, DNS
- Metadatos de tráfico cifrado: TLS handshake, certificados, IPs, tiempos
- Tramas WiFi (IEEE 802.11) si el adaptador soporta modo monitor
- Conversaciones entre hosts: quién habla con quién y cuánto

4.2 Conceptos clave

Concepto	Descripción
Modo promiscuo	La interfaz captura todos los paquetes de la red, no solo los destinados a ella
Modo monitor (WiFi)	Captura tramas 802.11 del aire sin estar conectado a ninguna red
Frame / Trama	Unidad de datos a nivel de enlace (capa 2) — incluye cabeceras Ethernet
Packet / Paquete	Unidad de datos a nivel de red (capa 3) — incluye cabeceras IP
Stream	Conversación completa entre dos endpoints (ej. toda una sesión HTTP)
PCAP	Formato de archivo para guardar capturas de tráfico (.pcap, .pcapng)
Disección	Wireshark descompone cada paquete en sus protocolos y campos

4.3 Filtros de captura y display más usados

```
# Filtros de display (aplicados sobre captura ya hecha)
http                          # Solo tráfico HTTP
dns                           # Solo consultas DNS
ip.addr == 192.168.1.100      # Solo tráfico de/hacia esa IP
tcp.port == 443               # Solo tráfico HTTPS
http.request.method == 'POST' # Solo peticiones POST
http contains 'password'      # Paquetes HTTP con 'password' en el contenido
!(arp or icmp or dns)         # Excluir tráfico de bajo nivel
tcp.flags.syn == 1            # Solo paquetes SYN (inicio de conexión)
```

4.4 Aplicaciones en seguridad

Uso	Descripción	Qué se busca
Detección de phishing	Analizar tráfico en la red en el momento del ataque	Peticiones POST a dominios desconocidos, DNS a dominios sospechosos

Análisis forense	Reconstruir qué ocurrió en un incidente de seguridad	Conexiones a C2, exfiltración de datos, movimiento lateral
Auditoría de protocolos	Verificar que servicios usen cifrado adecuado	Credenciales en texto plano (HTTP, FTP, Telnet)
Troubleshooting	Diagnosticar problemas de conectividad y rendimiento	Retransmisiones TCP, timeouts, latencia
Detección de malware	Identificar comportamiento de red anómalo	Beacon C2, DNS tunneling, conexiones inusuales

■ Wireshark puede capturar contraseñas, cookies y datos sensibles de tráfico no cifrado. Usarlo en redes propias o con autorización expresa. Capturar tráfico ajeno sin autorización es ilegal en la mayoría de países.

✔ Follow TCP Stream (clic derecho en un paquete → Follow → TCP Stream) reconstruye la conversación completa entre dos hosts, facilitando ver el contenido legible de sesiones HTTP, FTP u otros protocolos en texto plano.

5. Rootkits — Amenazas Persistentes Ocultas

Un rootkit es un conjunto de herramientas maliciosas diseñadas específicamente para **ocultar su presencia** en un sistema comprometido mientras mantienen acceso persistente. El nombre viene de 'root' (acceso privilegiado en Unix) + 'kit' (conjunto de herramientas).

5.1 Tipos de rootkits

Tipo	Dónde opera	Dificultad de detección	Ejemplo
User-mode (Ring 3)	Espacio de usuario — modifica binarios del sistema	Media — detectable con análisis de integridad	Ajeet, Lrk2
Kernel-mode (Ring 0)	Módulo del kernel — modifica el SO desde dentro	Alta — intercepta las llamadas al sistema	Adore, Reptile
Bootkit	MBR o UEFI — carga antes que el SO	Muy alta — invisible para el SO	Rovnix, Mebroot
Hypervisor	Se instala debajo del SO como thin hypervisor	Extremadamente alta — SO cree estar en hardware real	BluePill, Vitriol
Firmware	BIOS/UEFI/disco duro — sobrevive reinstalación del SO	Casi imposible sin hardware especializado	LoJax

5.2 Qué hace un rootkit una vez instalado

- **Oculta procesos**: el proceso malicioso no aparece en ps, top o el Administrador de tareas
- **Oculta archivos**: los archivos del malware no aparecen en ls o el explorador
- **Oculta conexiones**: las conexiones al C2 no aparecen en netstat
- **Oculta entradas en logs**: borra sus propias huellas de los registros del sistema
- **Backdoor persistente**: mantiene acceso aunque se cambie la contraseña
- **Keylogger**: captura contraseñas y otras teclas pulsadas
- **Escalación de privilegios**: otorga acceso root a procesos normales del atacante

5.3 Herramientas de detección

Herramienta	Tipo	Qué detecta	Instalación
chkrootkit	Escaneo	Rootkits conocidos comparando binarios	sudo apt install chkrootkit sudo chkrootkit
rkhunter	Escaneo	Rootkits, backdoors, exploits locales	sudo apt install rkhunter sudo rkhunter --check
AIDE	Integridad	Cambios en archivos del sistema (hash)	sudo apt install aide aide --init && aide --check
Volatility	Forense memoria	Rootkits en memoria RAM — análisis offline	pip install volatility3
GMER	Windows	Rootkits en Windows — análisis deep del kernel	Descarga directa de gmer.net
Lynis	Auditoría	Hardening y posibles indicadores de compromiso	sudo apt install lynis sudo lynis audit system

5.4 Técnicas de detección avanzada

- **Honeypots**: sistemas señuelo que detectan cuando un rootkit intenta propagarse
- **Análisis heurístico**: detectar comportamiento anómalo sin conocer el rootkit exacto
- **Comparación de hashes**: AIDE mantiene una base de datos de hashes de archivos del sistema
- **Verificación desde entorno limpio**: arrancar desde LiveCD y analizar el sistema sin ejecutarlo
- **Análisis de memoria**: Volatility puede encontrar procesos ocultos en el dump de RAM
- **Monitoreo de integridad continuo**: comparar estado actual vs. baseline conocido

■ Si sospechas de un rootkit kernel-mode activo, no confíes en NINGUNA herramienta que corra en ese mismo sistema — el rootkit puede mentirle a todas ellas. La detección debe hacerse desde un sistema externo o un LiveCD.

6. Normativas y Estándares de Seguridad

Las normativas de seguridad son marcos de referencia que definen qué debe hacer una organización para proteger su información. No reemplazan la tecnología — la complementan con procesos, políticas y cultura de seguridad.

6.1 ISO/IEC 27001 — Sistema de Gestión de Seguridad de la Información

ISO 27001 es el estándar internacional para implementar un **SGSI (Sistema de Gestión de Seguridad de la Información)**. No dice qué tecnología usar — dice cómo gestionar el riesgo de información de forma sistemática y auditable.

- **Basado en riesgos**: cada control se implementa porque existe un riesgo que lo justifica
- **No prescriptivo**: la organización decide qué controles aplicar según su contexto
- **Certificable**: una entidad de certificación audita y emite el certificado ISO 27001
- **Ciclo PDCA**: Plan → Do → Check → Act (mejora continua)

Estructura de la norma (capítulos 4–10):

Capítulo	Nombre	Contenido principal
4	Contexto de la organización	Entender el negocio, partes interesadas, alcance del SGSI
5	Liderazgo	Compromiso de la dirección, política de seguridad, roles y responsabilidades
6	Planificación	Análisis de riesgos y oportunidades, objetivos de seguridad, planes de tratamiento
7	Soporte	Recursos, competencias del personal, sensibilización, comunicación, documentación
8	Operación	Implementación de controles, gestión del cambio, evaluación y tratamiento de riesgos
9	Evaluación del desempeño	Monitoreo, auditorías internas, revisión por la dirección
10	Mejora	No conformidades, acciones correctivas, mejora continua del SGSI

Anexo A — 93 controles de seguridad (agrupados en 4 temas):

Tema	N° controles	Ejemplos de controles
Organizacional	37	Políticas, roles, gestión de activos, relaciones con proveedores
Personas	8	Selección de personal, formación, trabajo remoto
Físico	14	Perímetro físico, seguridad de equipos, escritorio limpio
Tecnológico	34	Control de acceso, cifrado, gestión de vulnerabilidades, logs

6.2 NIST Cybersecurity Framework (CSF)

El NIST CSF es un marco desarrollado por el Instituto Nacional de Estándares y Tecnología de EE.UU. Es más operativo que ISO 27001 y está orientado a gestionar y reducir el riesgo cibernético. Muy usado en sectores de infraestructura crítica.

Función NIST	Descripción	Actividades clave
IDENTIFY (ID)	Entender el contexto y los riesgos	Inventario de activos, evaluación de riesgos, políticas de gobierno
PROTECT (PR)	Implementar salvaguardas	Control de acceso, formación, cifrado, backups, hardening
DETECT (DE)	Identificar eventos de ciberseguridad	Monitoreo continuo, SIEM, detección de anomalías
RESPOND (RS)	Actuar ante incidentes detectados	Plan de respuesta, comunicación, análisis, mitigación
RECOVER (RC)	Restablecer capacidades después del incidente	Plan de recuperación, lecciones aprendidas, mejora

6.3 Análisis GAP (Brecha)

El análisis GAP (o de brecha) compara la situación actual de seguridad de una organización contra el estado deseado definido por una norma (ISO 27001, NIST, etc.).

- **Paso 1**: Describir la situación actual — qué controles existen, cómo funcionan
- **Paso 2**: Definir el estado deseado — requisitos de la norma elegida
- **Paso 3**: Identificar las brechas — qué falta, qué está incompleto
- **Paso 4**: Generar el plan de acción — priorizar y cerrar las brechas

✔ El resultado de un análisis GAP es un roadmap priorizado. Generalmente se prioriza según: severidad del riesgo × facilidad de implementación.

7. Conceptos Base de Seguridad

7.1 Seguridad TI vs. Seguridad de la Información

Dimensión	Seguridad TI	Seguridad de la Información
Enfoque	Tecnológico — sistemas, redes, dispositivos	Integral — personas, procesos, tecnología, físico y legal
Ámbito	Infraestructura técnica	Toda la información independientemente del soporte
Rol	Operativo — implementa y mantiene controles	Estratégico — define políticas, gestiona riesgos
Normas relacionadas	OWASP, CVE, CIS Benchmarks	ISO 27001, NIST CSF, COBIT, ENS
Ejemplo de actividad	Configurar un firewall, parchear un servidor	Definir la política de clasificación de información

Ambas disciplinas se complementan y convergen en marcos como ISO 27001, que requiere tanto controles técnicos como organizacionales y humanos.

7.2 Tríada CIA — Los tres pilares de la seguridad

Pilar	Nombre	Definición	Amenaza que lo rompe
C	Confidencialidad	Solo las personas autorizadas acceden a la información	Robo de datos, sniffing, credential harvesting
I	Integridad	La información no es alterada sin autorización	Tampering, inyección SQL, ransomware
A	Disponibilidad	La información está accesible cuando se necesita	DoS/DDoS, ransomware, fallos de hardware

7.3 Conocimientos base recomendados para ciberseguridad

Área	Qué aprender	Recursos sugeridos
Redes	Modelo OSI/TCP-IP, IP, DNS, puertos, subnetting, protocolos (HTTP, SSH, TLS, FTP)	Cisco Networking Academy, TryHackMe
Sistemas operativos	Linux (comandos, permisos, procesos, logs), Windows (Active Directory, registro, servicios)	OverTheWire: Bandit, Linux Journey, Microsoft Learn
Programación	Python (scripts de automatización y análisis), Bash (scripts de shell), PowerShell básico	Automate the Boring Stuff with Python, Shell Scripting
Inglés técnico	Documentación, CVEs, papers de seguridad, foros y comunidades en inglés	Práctica con documentación oficial de herramientas
Fundamentos de seguridad	Criptografía básica, PKI, certificados TLS, hashing, autenticación	CompTIA Security+, libros de criptografía

8. Resumen de Herramientas y Próximos Pasos

8.1 Tabla resumen de todas las herramientas

Herramienta	Categoría	Uso principal	Disponible en
TheHarvester	OSINT	Recopilar emails, subdominios, IPs de fuentes públicas	Kali Linux (incluido)
Shodan	OSINT	Buscar dispositivos expuestos en Internet	Web + CLI (pip install shodan)
Wireshark	Análisis de red	Capturar y analizar tráfico de red	Kali Linux (incluido)
tcpdump	Análisis de red	Captura de paquetes por terminal	Kali Linux (incluido)
chkrootkit	Defensa	Detectar rootkits conocidos en el sistema	sudo apt install chkrootkit
rkhunter	Defensa	Detectar rootkits, backdoors y exploits locales	sudo apt install rkhunter
AIDE	Defensa	Monitoreo de integridad de archivos del sistema	sudo apt install aide
Volatility 3	Forense	Análisis forense de memoria RAM	pip install volatility3
Lynis	Auditoría	Hardening y auditoría de seguridad de Linux	sudo apt install lynis
Nmap	Reconocimiento	Escaneo de puertos y detección de servicios	Kali Linux (incluido)
Metasploit	Pentesting	Framework de explotación de vulnerabilidades	Kali Linux (incluido)
Burp Suite	Web	Proxy para análisis y pentesting de aplicaciones web	Kali Linux (incluido)

8.2 Próximos pasos recomendados

Área	Acción concreta	Plataforma/Recurso
Práctica de comandos Linux	Completar las primeras 10 máquinas de OverTheWire Bandit	overthewire.org/wargames/bandit
Redes	Estudiar el modelo TCP/IP y hacer labs de Wireshark	Professor Messer, TryHackMe
ISO 27001	Leer los capítulos 4-6 y el Anexo A de la norma	ISO.org o versiones de estudio
NIST CSF	Revisar el framework en csrc.nist.gov	csrc.nist.gov/projects/cybersecurity-framework
OSINT avanzado	Practicar con OSINT Framework y casos reales propios	osintframework.com
Análisis de malware	Configurar una VM aislada y analizar samples con Volatility	VirusTotal
Laboratorio de pentesting	Crear un lab con VMs vulnerables (Metasploitable, DVWA)	TryHackMe, HackTheBox

---

Apuntes personales de ciberseguridad — base para estudio y profundización. TheHarvester · Shodan · Wireshark · Rootkits · ISO 27001 · NIST CSF.